



# ACTIVIDAD 04 - UNA PÁGINA DEMASIADO CONVINCENTE

Programación WAP

Prof: Servando Lopez Contreras

David Campos Morado - 183511  
Ingeniería en Tecnologías de la Información

## Indice

|                                                       |    |
|-------------------------------------------------------|----|
| Objetivo de la actividad .....                        | 2  |
| Descripción del escenario .....                       | 2  |
| Configuración del laboratorio .....                   | 2  |
| Evidencias y descripción del funcionamiento.....      | 2  |
| Explicación del flujo de captura de información ..... | 9  |
| Controles de seguridad propuestos.....                | 9  |
| Conclusion.....                                       | 10 |
| Referencia .....                                      | 10 |

## Objetivo de la actividad

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

## Descripción del escenario

El área de seguridad informática ha recibido reportes de empleados sobre un mensaje urgente acerca de una supuesta alerta o renovación obligatoria en el acceso a sus cámaras de seguridad. El enlace dirige a un portal de monitoreo aparentemente oficial que indica un fallo de sincronización o la necesidad de reautenticar el dispositivo. A primera vista, nada parece fuera de lo común, pero el portal falso no pertenece a la plataforma de vigilancia de la organización y está diseñado específicamente para engañar al usuario y capturar sus credenciales de acceso.

## Configuración del laboratorio

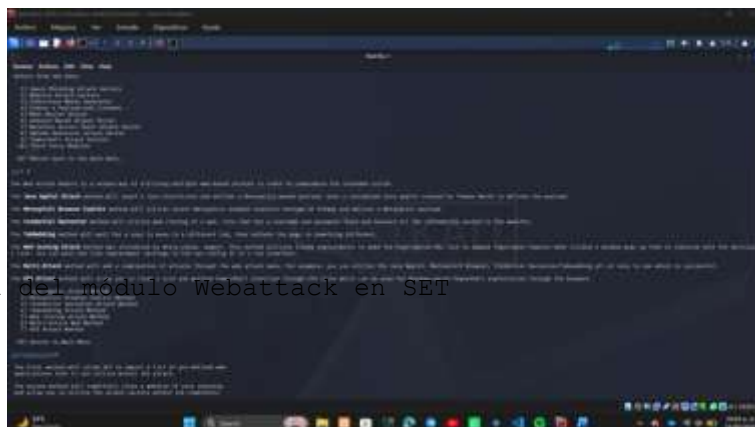
Para esta simulación, se utilizó el sistema operativo Kali Linux. Se configuró el módulo Credential Harvester Attack Method integrado en SET. Esta herramienta levanta un servidor web local (alojado en la IP de la máquina atacante) que clona la interfaz de acceso de una página web real o carga una plantilla predefinida, con el objetivo de escuchar e interceptar las peticiones HTTP POST.

## Evidencias y descripción del funcionamiento

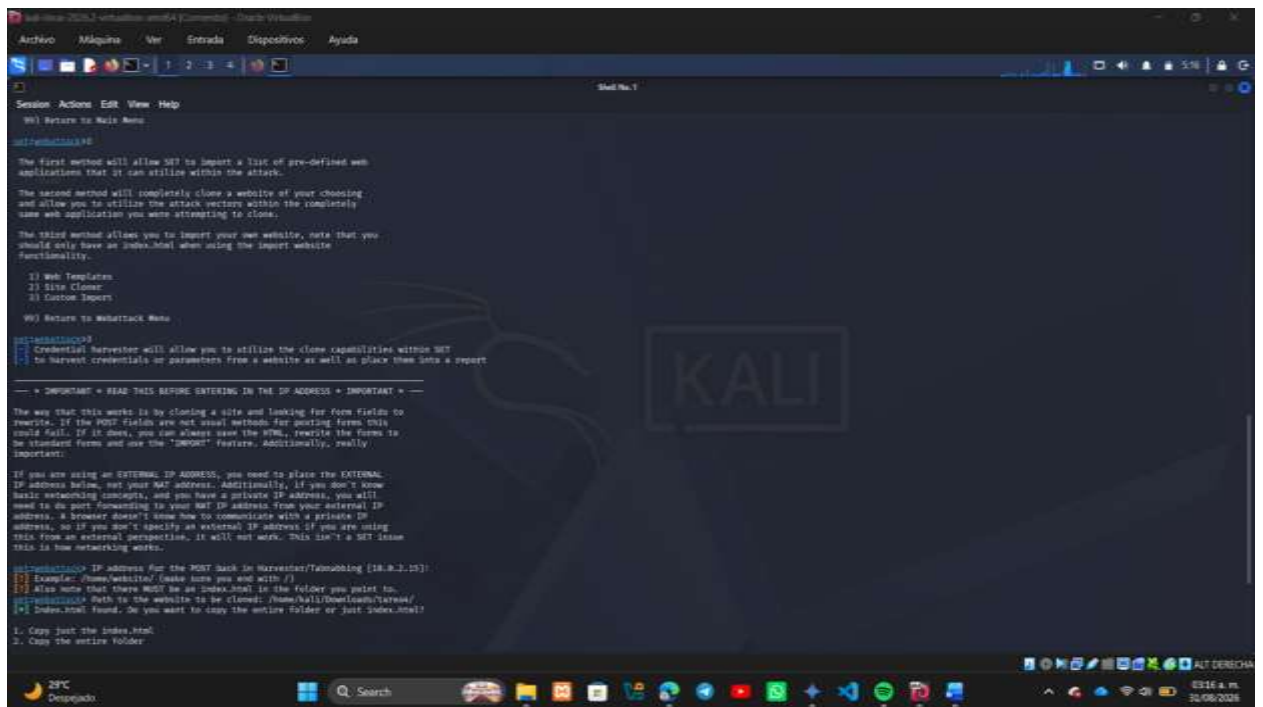
El flujo del ataque se ejecutó mediante las siguientes selecciones en la consola de SET:

```
Social-Engineering Attacks > 2) Website Attack Vectors > 3) Credential Harvester  
Attack Method > 3) Custom Import.
```

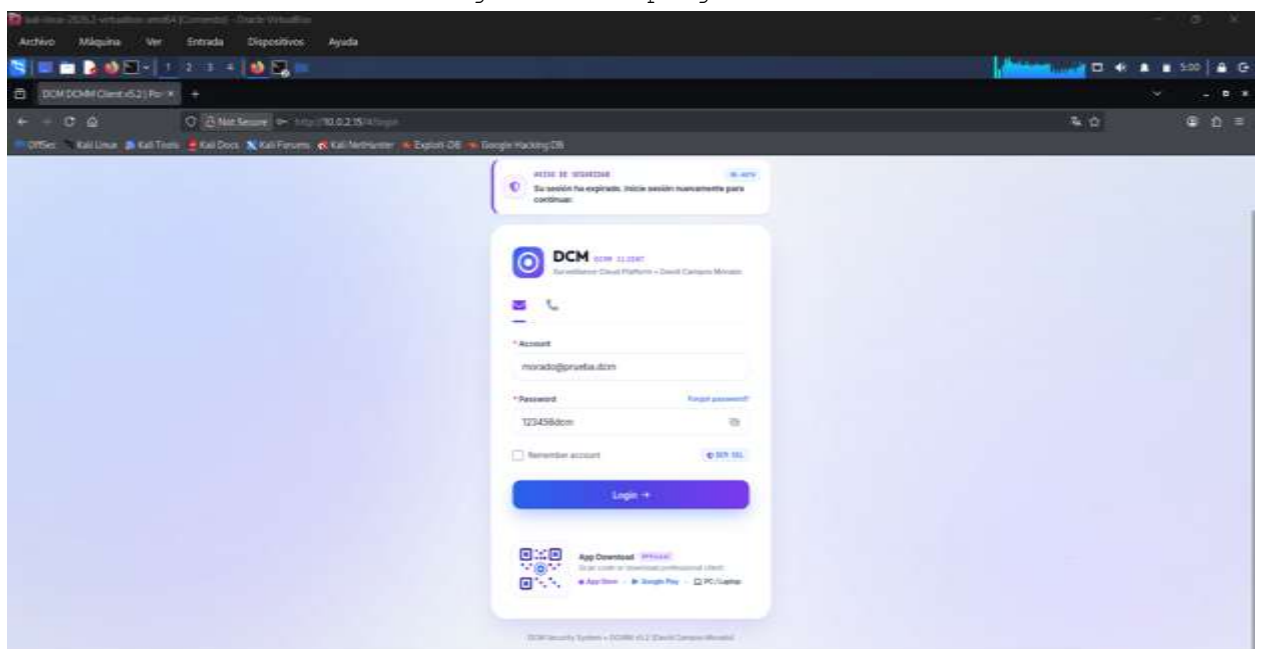
1) Selección del módulo Webattack en SET



2) Selección del módulo Webattack en SET



3) Portal falso de cámaras de seguridad desplegado



4) Intercepción exitosa del correo (morado@prueba.dcm) y contraseña en texto plano.



```

36 main class="flex-1 flex flex-col items-center justify-center p-4 sm:p-8 x-10% md:flex w-full max-w-[430px] flex flex-col item-center">
37
38 <div class="w-full mb-4 transition-all duration-300"><div class="bg-white/95 dark:bg-slate-900/95 backdrop-blur-md border-l-4 border-r-4 dcm-purpleMain border-
39 border-purple-300 dark:border-purple-900/40 rounded-2xl p-3.5 shadow-md flex items-center gap-3">
40 <div class="w-9 h-9 rounded-xl bg-purple-50 dark:bg-purple-900/60 border border-purple-200 dark:border-purple-900/40 flex items-center justify-center.
41 shrink-0 text-dcm-purpleMain dark:text-purple-300"><i class="fa-solid fa-shield-halved animate-pulse">/i></div>
42 <div class="flex-1 min-w-0"><div class="flex items-center justify-between"><span class="text-[14px] font-mono font-bold text-dcm-purpleDeep
43 dark:text-purple-400 uppercase">Avatar</span><span class="text-[5px] font-mono font-bold bg-dcm-blueSoft dark:bg-blue-900/60 text-dcm-blueMain
44 dark:text-blue-300 px-2 py-0.5 rounded-full border border-blue-300 dark:border-blue-900/30"&>SESIÓN HA EXPIRADO</span></div><p id="tsAI"
45 class="text-sm sm:text-[12-5px] font-normal text-slate-500 dark:text-slate-400 mt-0.5">Su sesión ha expirado. Inicie sesión nuevamente para continuar.</p>
46 </div></div>
47
48 <div class="w-full bg-white dark:bg-slate-900/95 rounded-2xl p-6 sm:p-8 shadow-2xl border border-white/80 dark:border-slate-800/90 relative backdrop-blur-se">
49 <div class="flex items-center gap-1.5 mb-7"><div class="w-12 h-12 relative flex items-center justify-center shrink-0">
50 <svg class="w-12 h-12 viewBox=0 0 64 64 fill:none stroke-width=6 stroke-height=6 stroke=none"><circle cx=32 cy=32 r=10 stroke="#fff"
51 stroke-width=4.5"/>
52 <circle cx=32 cy=32 r=8 fill="#fff"><circle cx=26 cy=26 r=3 fill="#3333ff"></div><div class="relative">gradient</div>
53 gradientUnits="userSpaceOnUse" stop-stop-color=#2e3192 stop-offset=73 stop-color=#f3f3f3"></div></div></div>
54 </div></div><div class="flex items-baseline gap-3"><div class="font-outfit font-extrabold text-2xl text-slate-800 dark:text-slate-light leading-none">
55 KCS</div><div class="text-[14px] font-bold text-dcm-purpleMain dark:text-purple-400 uppercase tracking-widest font-mono">DCPM CLIENTE</div></div>
56 <div class="text-[11-5px] text-slate-500 dark:text-slate-400 font-medium leading-tight wt-cl">Surveillance Cloud • David Campos Morado</div></div>
57
58 <div class="flex items-center gap-8 mb-8 border-b border-slate-300 dark:border-slate-800 relative"><button type="button" onclick="swf('c')
59 class="pb-1 text-dcm-purpleMain dark:text-purple-400 flex justify-center relative transition-colors cursor-pointer" id="tbl">c</div>
60 class="fa-solid fa-envelope text-xl">/i></div><div class="absolute bottom-0 left-0 right-0 h-[30px] bg-gradient-to-r from-dcm-blueMain to-dcm-purpleMain
61 rounded-full"></div></div><div class="font-outfit font-extrabold text-2xl text-slate-800 dark:text-slate-light leading-none">
62 justify-center relative transition-colors cursor-pointer" id="tbl">c</div><div class="fa-solid fa-phone text-lg">/i></div><div class="in"
63 class="absolute bottom-0 left-0 right-0 h-[30px] bg-transparent rounded-full"></div></div></div>
64
65 <form id="frm" method="POST" onsubmit="vld(event)" novalidate class="space-y-4">
66 <div class="space-y-1.5"><label class="block text-sm font-semibold text-slate-700 dark:text-slate-300"><span class="text-red-500 font-bold">*</span>
67 <span id="inputEmail">Account</span></div><div class="relative"><input type="text" id="ia" name="email" placeholder="Enter your email address"
68 value="" autocomplete="off" oninput="ctrl('ia')"></div><div class="min-w-full mx-1.5 my-2 rounded-xl border border-slate-200 dark:border-slate-700 bg-white

```





```

36 |         @2 class="text-2xl md:text-3xl text-white font-bold text-center sm-6 tracking-wide">
37 |         | gracias por entrar a este link!
38 |         </h2>
39 |
40 |
41 |         <div class="relative group cursor-pointer" id="image-container">
42 |             <div class="absolute -inset-4 bg-gradient-to-r from-pink-400 to-purple-600 rounded-xl blur opacity-75 group-hover:opacity-100 transition duration-1000 group-
43 |             
45 |             <p class="text-gray-400 mt-4 text-sm">{Esto solo es una tarea*Por mas atencion a las paginas que entran}</p>
46 |             <p class="text-gray-400 mt-4 text-sm">{Si quieres mas confeti picala a la imagen}</p>
47 |         </div>
48 |
49 |         <audio id="bg-music" loop>
50 |             <source src="http://upload.wikimedia.org/wikipedia/commons/4/43/Entry_of_the_Gladiators.ogg" type="audio/ogg">
51 |         </audio>
52 |
53 |         <script>
54 |             const startBtn = document.getElementById('start-btn');
55 |             const startScreen = document.getElementById('start-screen');
56 |             const mainContent = document.getElementById('main-content');
57 |             const bgMusic = document.getElementById('bg-music');
58 |             const imgContainer = document.getElementById('image-container');
59 |
60 |             // Función de confeti
61 |             function fireConfetti() {
62 |                 var duration = 5 * 1000;
63 |                 var animationFnd = Date.now() + duration;
64 |                 var defaults = { startVelocity: 30, spread: 360, ticks: 60, zindex: 0 };
65 |
66 |                 function randomRange(min, max) {
67 |                     return Math.random() * (max - min) + min;
68 |                 }

```

```

60 |             // Función de confeti
61 |             function fireConfetti() {
62 |                 var duration = 5 * 1000;
63 |                 var animationFnd = Date.now() + duration;
64 |                 // animar 'la trama' a 'nacer' solo en su momento
65 |             }
66 |             startBtn.addEventListener('click', () => {
67 |                 // Ocultar pantalla de inicio
68 |                 startScreen.classList.add('hidden');
69 |
70 |                 // Mostrar contenido principal con un fade in
71 |                 mainContent.classList.remove('hidden');
72 |                 setTimeout(() => {
73 |                     mainContent.classList.remove('opacity-0');
74 |                     mainContent.classList.add('opacity-100');
75 |                 }, 50);
76 |
77 |                 // Reproducir la canción
78 |                 bgMusic.volume = 0.5; // Ajustar volumen si es necesario
79 |                 bgMusic.play();
80 |
81 |                 // Explosión inicial de confeti
82 |                 confetti({
83 |                     particleCount: 150,
84 |                     spread: 180,
85 |                     origin: { y: 0.6 }
86 |                 });
87 |
88 |                 // Iniciar lluvia de confeti
89 |                 setTimeout(fireConfetti, 500);
90 |             });
91 |
92 |             // Clic en la imagen para más confeti
93 |             imgContainer.addEventListener('click', () => {
94 |                 confetti({

```

```

117 |
118 |             // Clic en la imagen para más confeti
119 |             imgContainer.addEventListener('click', () => {
120 |                 confetti({
121 |                     particleCount: 100,
122 |                     spread: 90,
123 |                     origin: { y: 0.6 }
124 |                 });
125 |             });
126 |         </script>
127 |     </body>
128 | </html>

```

## Explicación del flujo de captura de información

El proceso técnico inicia cuando la víctima accede a la IP local configurada (10.0.2.15). Al ingresar sus datos y hacer clic en el botón de "Login", el formulario HTML de la página clonada genera una petición HTTP POST. Como la conexión viaja a través del puerto 80 y carece de cifrado (ausencia de HTTPS), la carga útil viaja en texto claro. El servidor de SET, que está a la escucha en ese mismo puerto, captura las variables de la cabecera POST correspondientes al correo y la contraseña, imprimiéndolas directamente en la terminal del atacante.

## Controles de seguridad propuestos

Al hacer esta práctica me quedó claro que para frenar ataques de phishing no basta con una sola barrera. Las empresas reales necesitan aplicar una estrategia de **seguridad en profundidad** que proteja tanto su red como a las personas. Los pasos esenciales que debemos seguir son:

- **Blindar los accesos corporativos:** Dejar de depender únicamente de contraseñas fáciles de robar.
- **Filtrar vectores de entrada:** Detener los correos y enlaces falsos antes de que lleguen a los empleados.
- **Monitorear y educar constantemente:** Enseñar al personal a desconfiar y verificar siempre.

Llevando esto a la práctica, estos son los controles de seguridad más efectivos que debemos atender:

- **Autenticación Multifactor (MFA):** Te pide un segundo código o token físico. Aunque el atacante te robe la contraseña en la página falsa, no podrá entrar sin ese segundo paso.
- **Filtros de Correo (SEG):** Se encargan de bloquear mensajes maliciosos y dominios parecidos antes de que siquiera aparezcan en la bandeja de entrada.
- **Capacitación del Personal:** Entrenar al equipo con simulacros reales para que aprendan a detectar tácticas de presión y enlaces extraños.
- **Análisis y Filtrado Web:** Bloquean automáticamente las conexiones a direcciones IP directas o portales nuevos que no tienen un dominio seguro registrado.
- **Certificados SSL y HSTS:** Obligan a que todo viaje por HTTPS, evitando que las contraseñas se manden volando en texto plano por el puerto 80.

- **Registros de Dominio (SPF, DKIM y DMARC):** Validan quién manda realmente los correos institucionales para evitar que cualquiera suplante a la empresa.

## Conclusion

Con esta práctica me di cuenta de lo rápido y sencillo que es clonar una página usando herramientas como SET. A veces uno piensa que hacer estos ataques es algo muy difícil o que solo pasa en las películas, pero la verdad es que con una página que se vea bonita y metiéndole un poco de presión al usuario, la gente solita pone su contraseña sin dudarlo.

Ver cómo te llegan los correos y las contraseñas directamente a la terminal me hizo entender que no se necesita ser un experto en programación para burlar un sistema si logras engañar a la persona que lo usa.

Como estudiante de Tecnologías de la Información (ITI), hacer estas pruebas me sirve muchísimo para ver cómo funcionan estas trampas en la vida real. Me deja como enseñanza que nuestra responsabilidad es usar lo que aprendemos para cosas buenas (como un hacker de sombrero blanco) y ayudar a implementar medidas de seguridad en las empresas, porque al final del día, más vale prevenir que lamentar.

## Referencia

TrustedSec (David Kennedy). (s.f.). The Social-Engineer Toolkit (SET). Repositorio oficial y documentación operativa del módulo Credential Harvester. Disponible en: [github.com/trustedsec/social-engineer-toolkit](https://github.com/trustedsec/social-engineer-toolkit)

OffSec. (2026). Kali Linux Documentation: Tools & Services. Base de conocimientos sobre el despliegue de servidores locales en entornos de pruebas ofensivas. Disponible en: [www.kali.org/docs/](http://www.kali.org/docs/)

OWASP Foundation. (2026). Credential Stuffing and Phishing Prevention Cheat Sheet. Guía técnica de referencia para la formulación de los controles de mitigación.

López Contreras, S. (2026). Material y Rúbricas de Laboratorio - CNO IV: Seguridad Informática. Universidad Politécnica de San Luis Potosí (UPSLP).